

Planificación de cambios en el Sistema de Gestión de la Seguridad de la Información (SGSI)

Basado en ISO 27001:2022 – Cláusula 6.3

Cuando la organización determine la necesidad de realizar cambios en el SGSI (ya sean técnicos, organizativos, documentales o de procesos), dichos cambios se ejecutarán de forma planificada, controlada y documentada, con el fin de prevenir efectos no deseados sobre la confidencialidad, integridad y disponibilidad de la información, y de garantizar la mejora continua del sistema.

1. Identificación y origen del cambio

Cualquier responsable de proceso, miembro del equipo TIC, auditor interno o directivo podrá identificar la necesidad de un cambio en el SGSI.

La solicitud se remitirá al Responsable del SGSI mediante correo corporativo o herramienta de gestión de incidencias.

Se evaluará inicialmente:

Impacto en los requisitos de seguridad de la información.

Afectación a procesos ya documentados.

Necesidad de recursos adicionales.

Posibles efectos sobre el tratamiento de datos personales (RGPD/LOPDGDD).

Alineamiento con la política de seguridad y los objetivos del SGSI.

2. Evaluación y autorización previa

El Responsable del SGSI realizará un análisis de riesgos específico para el cambio propuesto, identificando:

- Vulnerabilidades que pueda introducir.
- Activos afectados.
- Probabilidad e impacto en caso de fallo.

Niveles de autorización:

Cambios menores (actualización documental, cambios de usuario sin privilegios): autoriza el Responsable del SGSI.

Cambios significativos (modificación de controles, actualización de software crítico, cambios en accesos generales, alteración de la declaración de aplicabilidad): requiere aprobación por escrito de la Dirección.

Cambios en entornos regulados (ENS, RGPD): se requiere además informe del Delegado de Protección de Datos (DPD) si afecta a datos personales.

Toda solicitud aprobada se registrará en el Registro de Cambios del SGSI.

3. Planificación detallada del cambio

Para cada cambio autorizado se elaborará un Plan de Cambio que incluirá como mínimo:

Objetivo y alcance del cambio.

- Responsables de ejecución (con roles claramente definidos).
- Recursos necesarios (humanos, técnicos, licencias, tiempos).
- Entorno de pruebas (cuando sea técnicamente posible y crítico).
- Copias de seguridad previas (verificadas y restaurables).
- Ventana de implementación (preferiblemente fuera de horas de máxima actividad).
- Plan de comunicación a partes interesadas internas y externas.
- Plan de reversión (rollback) detallado y probado.
- Criterios de éxito para dar por finalizado el cambio.

4. Implementación controlada

La ejecución del cambio se realizará exclusivamente por personal autorizado y capacitado.

Durante la implementación:

- Se seguirá estrictamente el plan aprobado.
- Se registrarán todas las acciones en el registro de cambios y en los logs técnicos.
- Se dispondrá de acceso inmediato al plan de contingencia.
- No se introducirán cambios adicionales no planificados.
- En caso de desviación o incidencia no prevista, se activará el plan de reversión sin esperar a la finalización del plazo.

5. Pruebas de validación y aceptación

Una vez ejecutado el cambio, se realizarán pruebas funcionales y de seguridad para verificar:

- Que el cambio cumple los objetivos definidos.
- Que no se han afectado otros controles del SGSI.
- Que la operativa habitual se mantiene.
- Que no se han generado nuevas vulnerabilidades.

- Las pruebas serán documentadas y firmadas por el ejecutor y el validador (preferentemente una persona distinta).
- Solo tras la validación positiva se dará por cerrada la implementación.

6. Cierre, documentación y seguimiento

Una vez validado el cambio:

- Se actualizarán los documentos del SGSI afectados (procedimientos, inventario de activos, análisis de riesgos, declaración de aplicabilidad, etc.).
- Se archivará el expediente completo (solicitud, análisis, plan, logs, pruebas, autorizaciones) en el repositorio del SGSI con control de accesos.
- Se comunicará el cierre a las partes interesadas afectadas.
- Se programará un seguimiento (generalmente a los 30 días) para verificar estabilidad.

7. Cambios de emergencia o no planificados

Excepcionalmente, podrá ejecutarse un cambio sin la planificación completa si existe una amenaza inminente (ej. parche de seguridad crítica, fallo grave).

En ese caso:

- Se ejecutará con el mínimo personal necesario y bajo supervisión directa del Responsable del SGSI.
- Se documentará la urgencia y la justificación.
- En un plazo máximo de 48 horas se completará toda la documentación reglamentaria del punto 6.3.
- Se realizará una revisión posterior para evitar recurrencias innecesarias de cambios de emergencia.